

Foundations of Cryptography

BCS2420

Dr. Ashish Sai

ashish.sai@maastrichtuniversity.nl

Cryptography is the foundational building blocks for computer security, analogous to the ⚡ electrical wiring and 🔌 power supply in house-building.



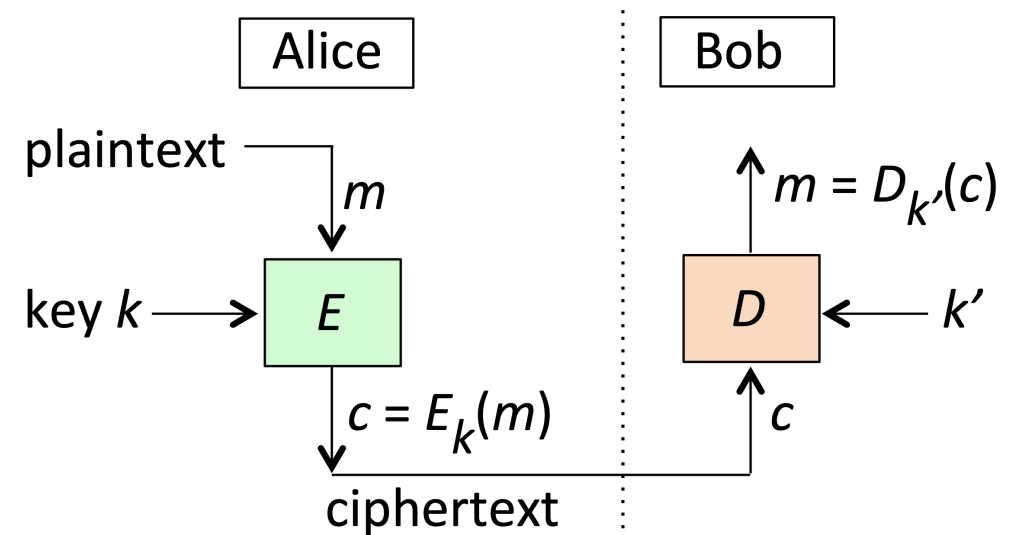
Encryption and Decryption

What is Encryption 🔒 and Decryption 🔓?

- Encryption algorithms **transform** data (plaintext) into an unintelligible form (ciphertext) to provide data confidentiality.
- Decryption algorithms reverse the process using a decryption key to recover the plaintext.

Key Terms

- **Plaintext:** Original data.
- **Ciphertext:** Encrypted data.
- **Encryption Key:** Used to encrypt data.
- **Decryption Key:** Used to decrypt data.



Generic Encryption Notation

Let m denote a plaintext message, c the ciphertext, and E_k , $D_{k'}$ the encryption and decryption algorithms parameterized by symmetric keys k , k' respectively.

Equations

$$c = E_k(m)$$

$$m = D_{k'}(c)$$

Caesar Cipher Example

Caesar's famous cipher was rather *simple*.

The encryption algorithm simply substituted each alphabetic plaintext character by that occurring **three letters later** in the alphabet.

Key Search

An attacker **must** try **all keys** in the key space ¹, expecting to find the **correct key** after trying half of the key space. For a 128-bit key, this means trying approximately $(2^{\{127\}})$ keys.

1. Key Space: The total set of possible keys in a cryptographic algorithm, determining its strength and resistance to brute-force attacks. ↩

Exhaustive Key Search

A **critical** property of **good** encryption algorithms is that it should be infeasible to recover plaintext from ciphertext without knowledge of the decryption key.

Example: DES Key Space

The **DES** (*Data Encryption Standard*) key space (56 bits) can be visualized as a 3,900-km super-highway from Lisbon, Portugal to Istanbul, Turkey, 316 lanes wide and tall, filled with white golf balls except for one black ball.

Cipher Attack Models

Types of Attacks

1. **Ciphertext-Only Attack:** Recover plaintext or key from ciphertext alone.
2. **Known-Plaintext Attack:** Given some plaintext and corresponding ciphertext, recover unknown plaintext or key from further ciphertext.
3. **Chosen-Plaintext Attack:** Adversary chooses plaintext and sees resulting ciphertext.
4. **Chosen-Ciphertext Attack:** Adversary chooses ciphertext and receives corresponding plaintext.

Side note: Passive vs. Active Adversary

1. Passive Adversary

- **Observes** and **records** but does **not** alter information.

2. Active Adversary

- **Interacts** with ongoing transmissions by injecting data or altering them, or starts new interactions with legitimate parties.

Symmetric-Key Encryption and Decryption

Symmetric-Key Encryption

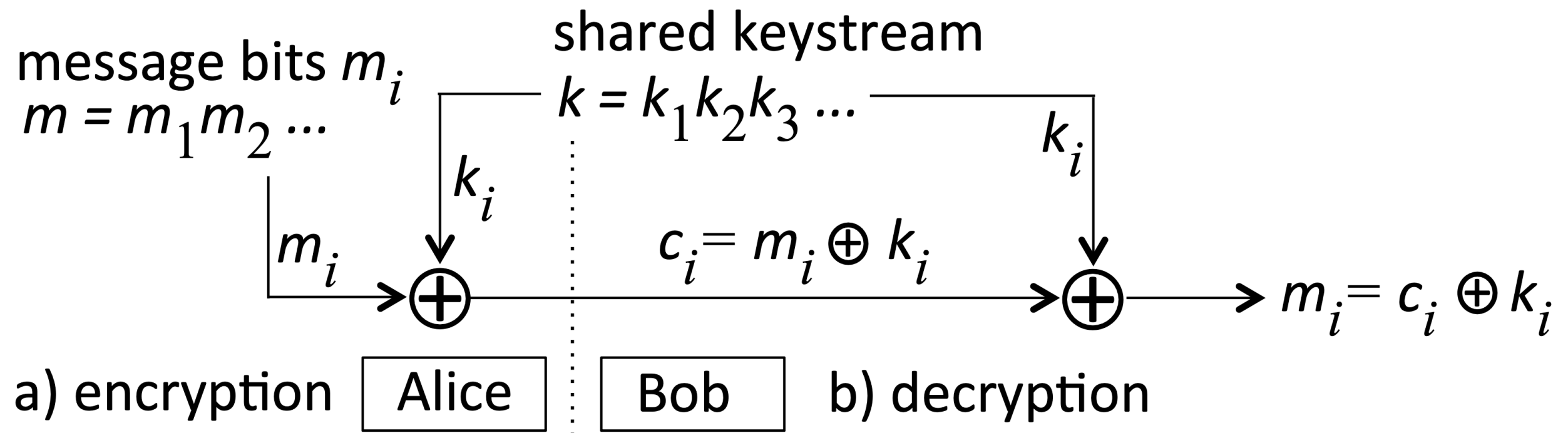
In symmetric-key encryption, the encryption and decryption keys are the **same**.

Example: Vernam Cipher

- The Vernam cipher encrypts plaintext **one bit** at a time using a **key** as long as the plaintext.

$$c_i = m_i \oplus k_i$$

$$m_i = c_i \oplus k_i$$



Stream Ciphers

Stream ciphers encrypt plaintext **one bit** or **one character** at a time.

The Vernam cipher is an example of a stream cipher

Block Ciphers

Block ciphers process plaintext in **fixed-length** chunks or **blocks**.

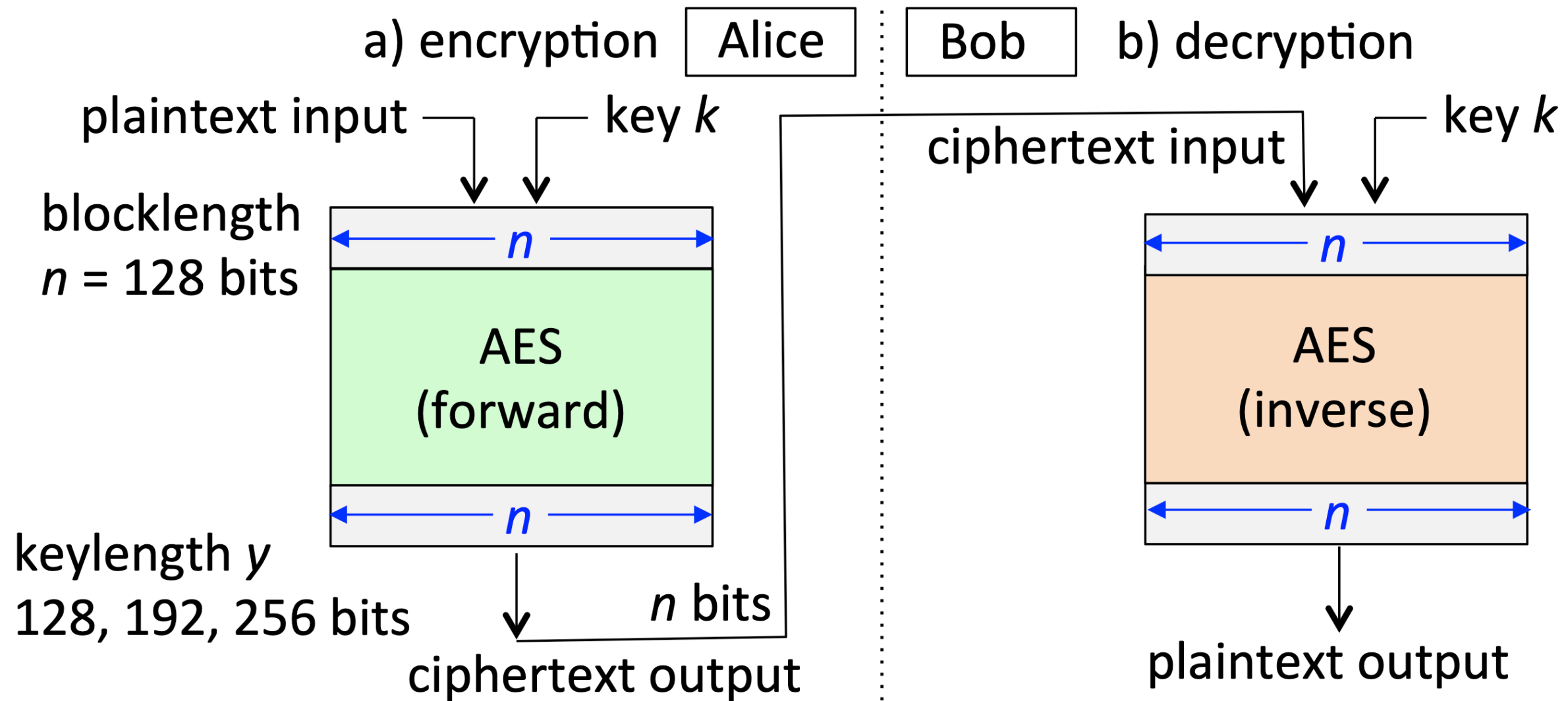
Properties:

- **Blocklength**: block size in bits
- **Keylength**: key size in bits

If the last plaintext block has fewer bits than the blocklength, it is padded with “filler” characters

Example: AES Block Cipher

AES (**Advanced Encryption Standard**) is widely used today, created by researchers at KU Leuven 🇧🇪.



Block Cipher Modes

ECB and CBC Modes

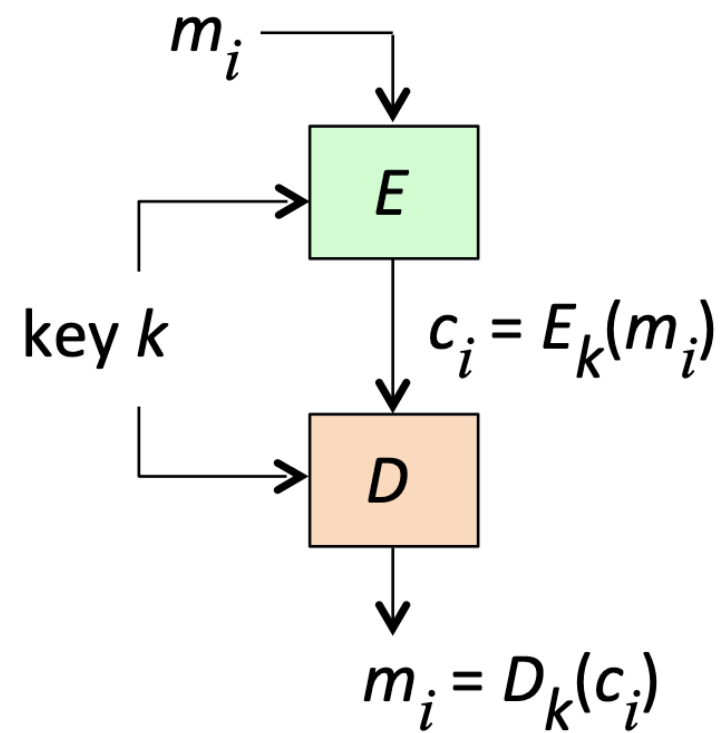
1. ECB Mode

- Electronic Code-Book (ECB) mode encrypts each block independently.

2. CBC Mode

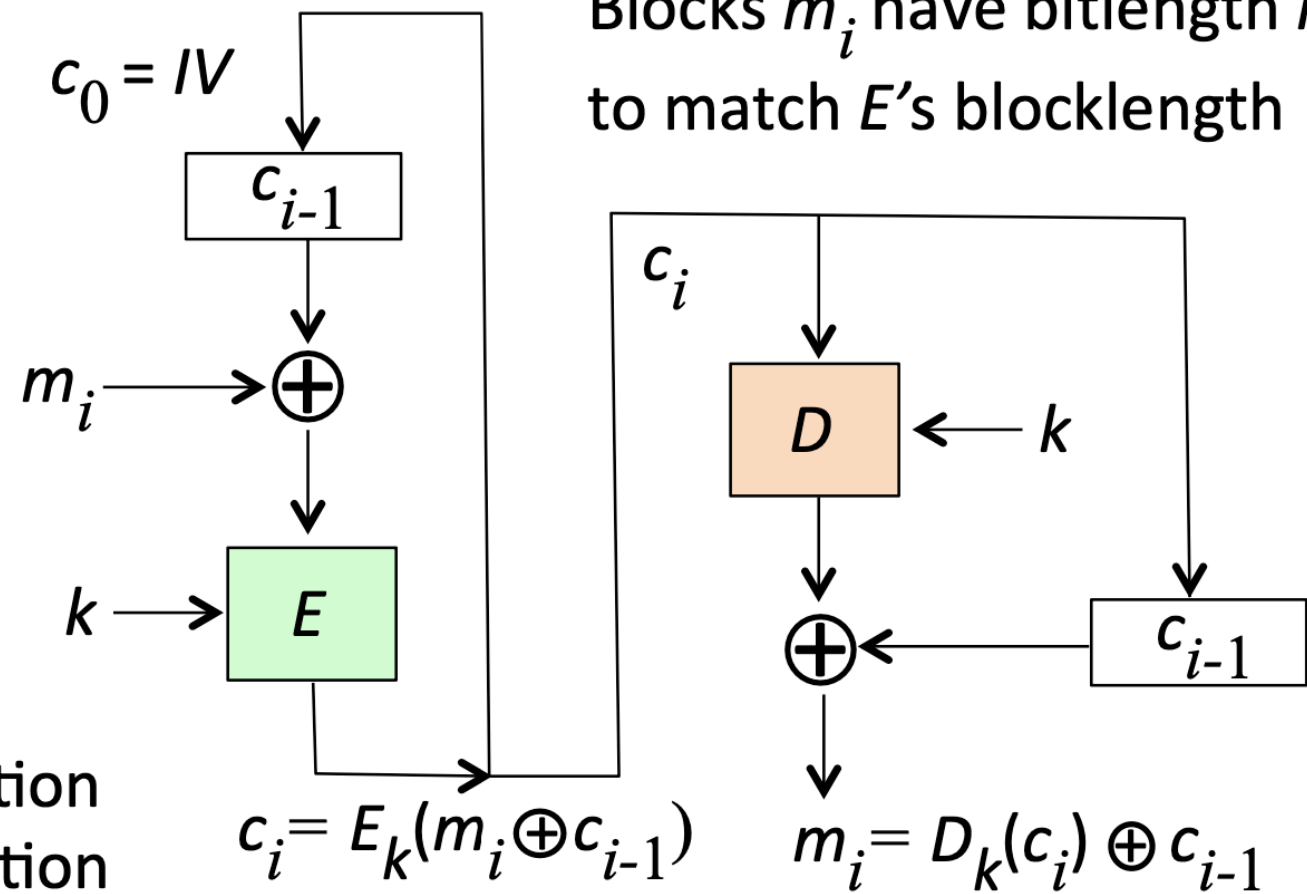
- Cipher-Block Chaining (CBC) mode encrypts each block with a previous block's ciphertext.

a) ECB mode



E: block cipher, encrypt operation
D: block cipher, decrypt operation

b) CBC mode

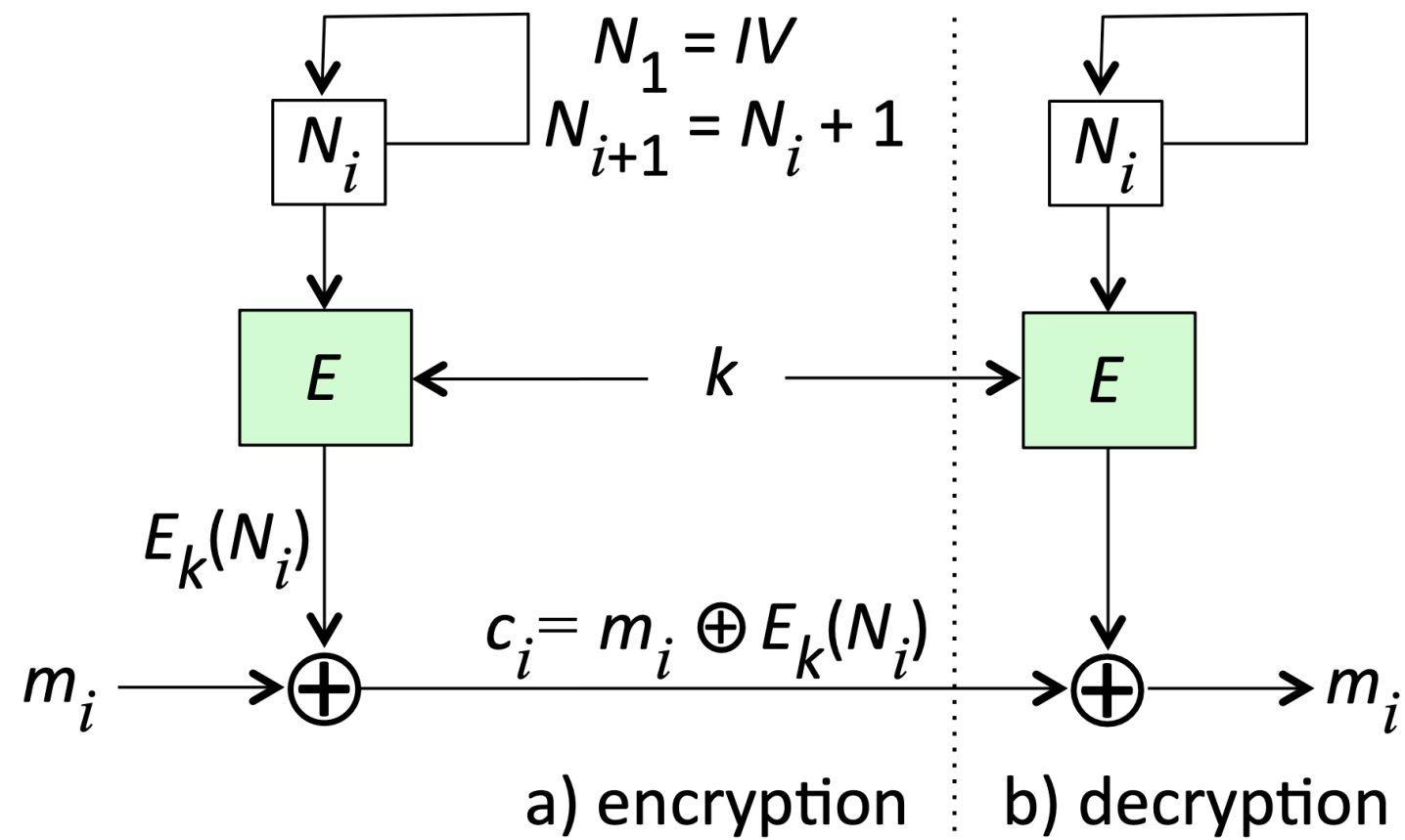


Message $m = m_1 m_2 m_3 \dots m_t$
Blocks m_i have bitlength n ,
to match E 's blocklength

Counter Mode (CTR)

- **CTR Mode**

- Uses a counter value to generate a **keystream**, which is then **XORed** with plaintext blocks.



Counter (CTR) mode

Message $m = m_1 m_2 \dots m_t$
is encrypted to yield
ciphertext $c = c_1 c_2 \dots c_t$

Blocks m_i, c_i are n bits

Public-Key Encryption and Decryption

Public-Key Encryption

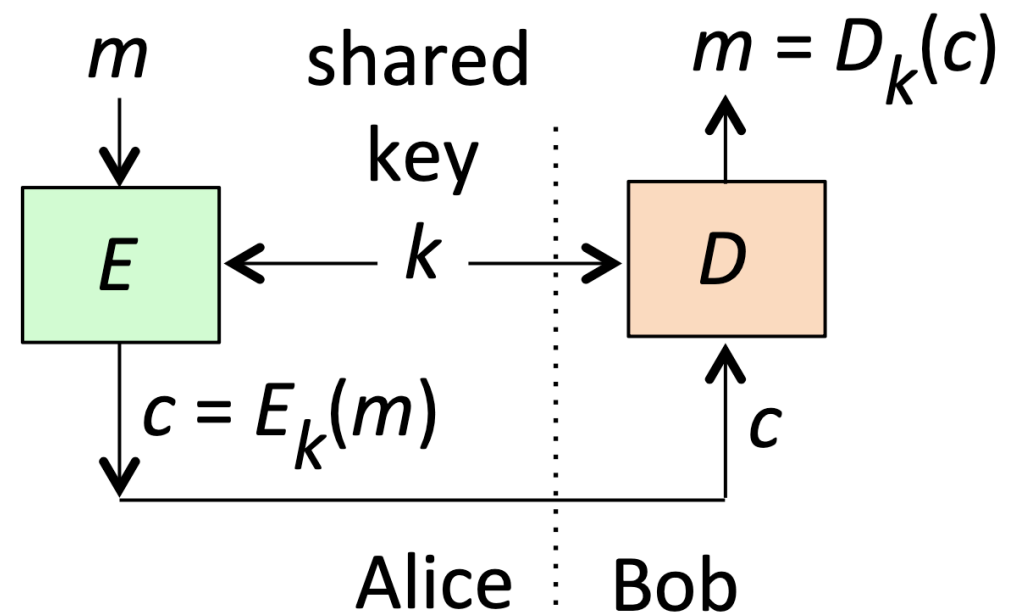
In public-key encryption, each party has a **key pair** consisting of an encryption public key and a decryption private key.

Equations

$$c = E_{e_B}(m)$$

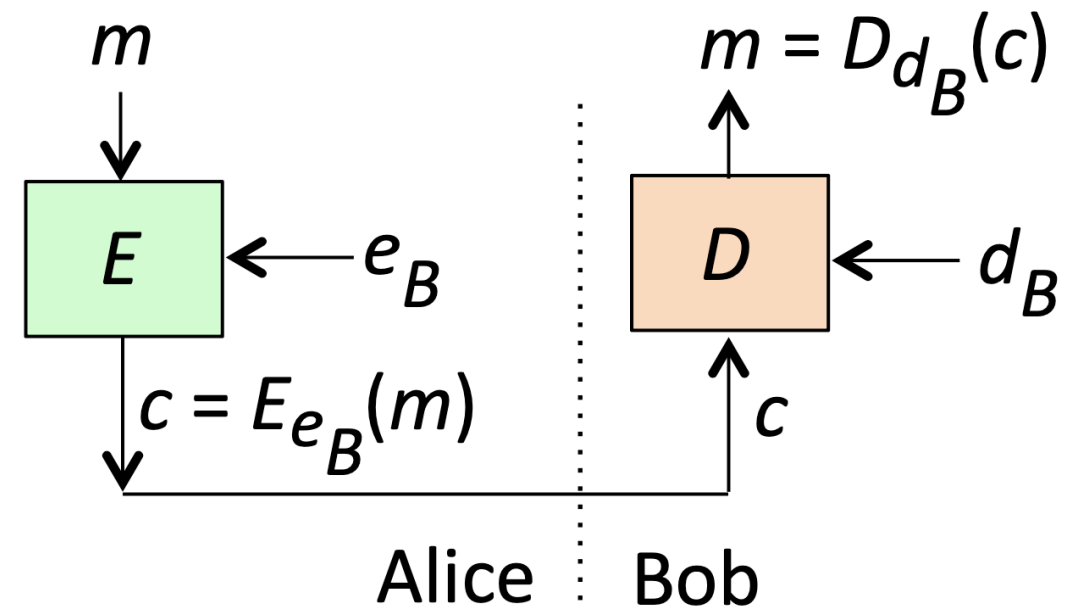
$$m = D_{d_B}(c)$$

a) Symmetric-key encryption



m : plaintext, c : ciphertext

b) Public-key encryption



e_B : Bob's encryption public key

d_B : Bob's decryption private key

Integrity of Keys

- A **public key** can be *published*, but its *integrity* and *authenticity* are critical.
- A **private key** is **not** published

Hybrid Encryption

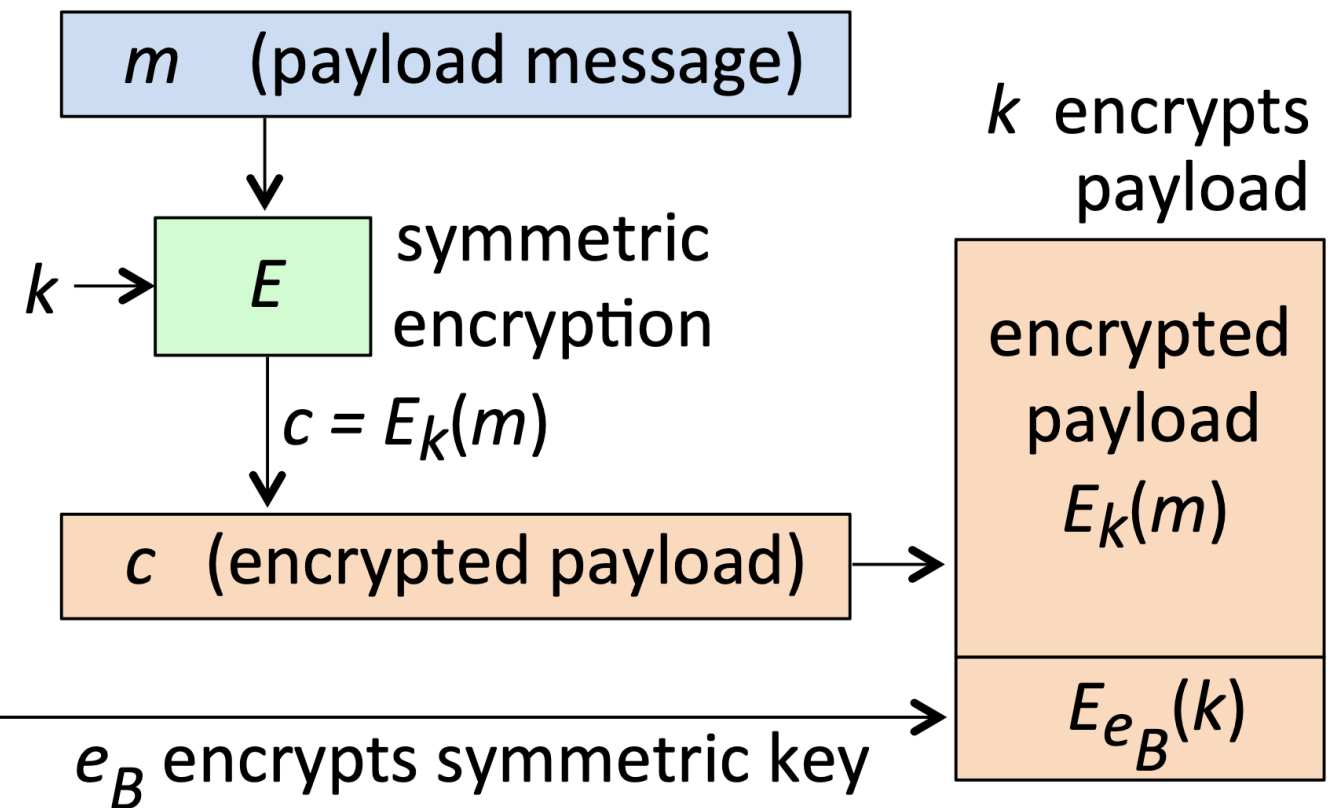
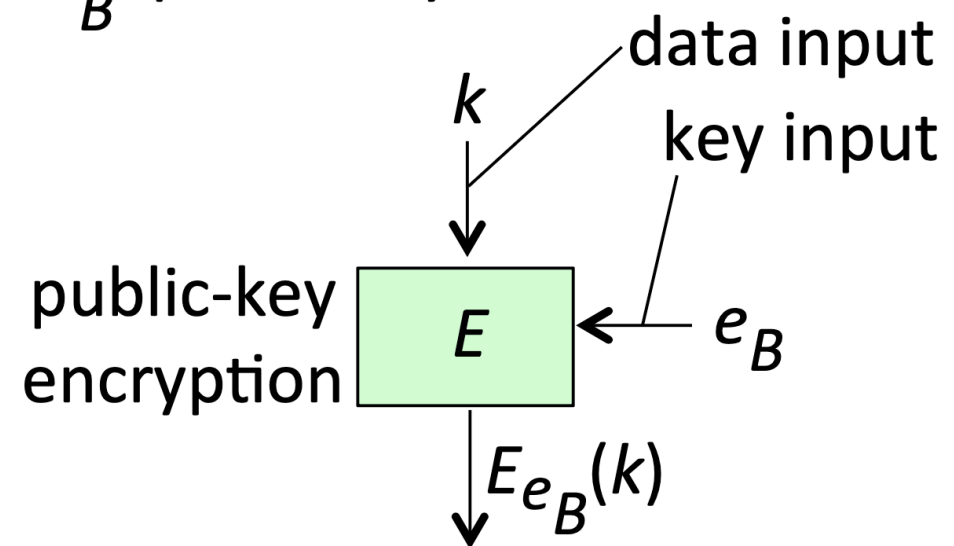
- Combines the **efficiency** of *symmetric-key encryption* for bulk data with the **convenience** of *public-key encryption* for key distribution.

Process

1. Generate a symmetric key k .
2. Encrypt the message m with k .
3. Encrypt k with the recipient's public key e_B .

k : symmetric key

e_B : public key



ALICE'S APARTMENT

HEY BOB!

CAN YOU PLEASE
CREATE A PUBLIC-PRIVATE
KEY PAIR AND GIVE ME
YOUR PUBLIC KEY?

SURE ALICE

THIS IDIOTIC EVE IS
READING ALL OUR EMAILS

NO, PROBLEM
I'LL TEXT YOU MY
PUBLIC KEY

Digital Signatures

Application of Public Key Cryptography

Digital Signature

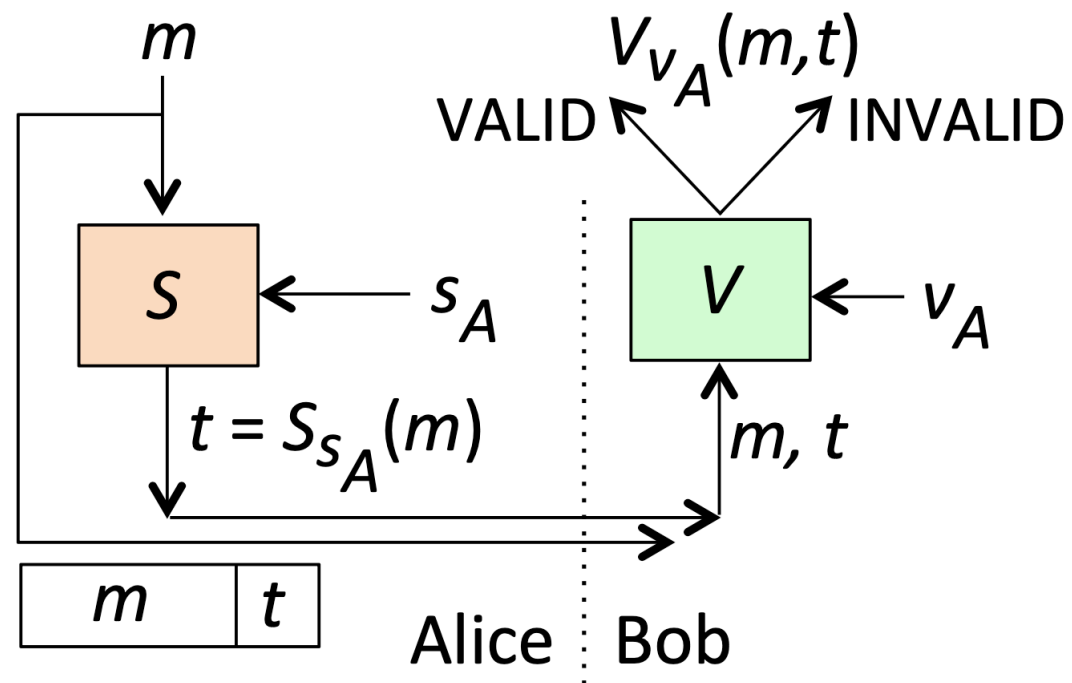
Digital signatures provide data origin authentication, data integrity, and non-repudiation¹.

1. Non-repudiation ensures that a party in a communication cannot deny the authenticity of their signature, message, or action, providing proof of origin and integrity. ↩

Properties

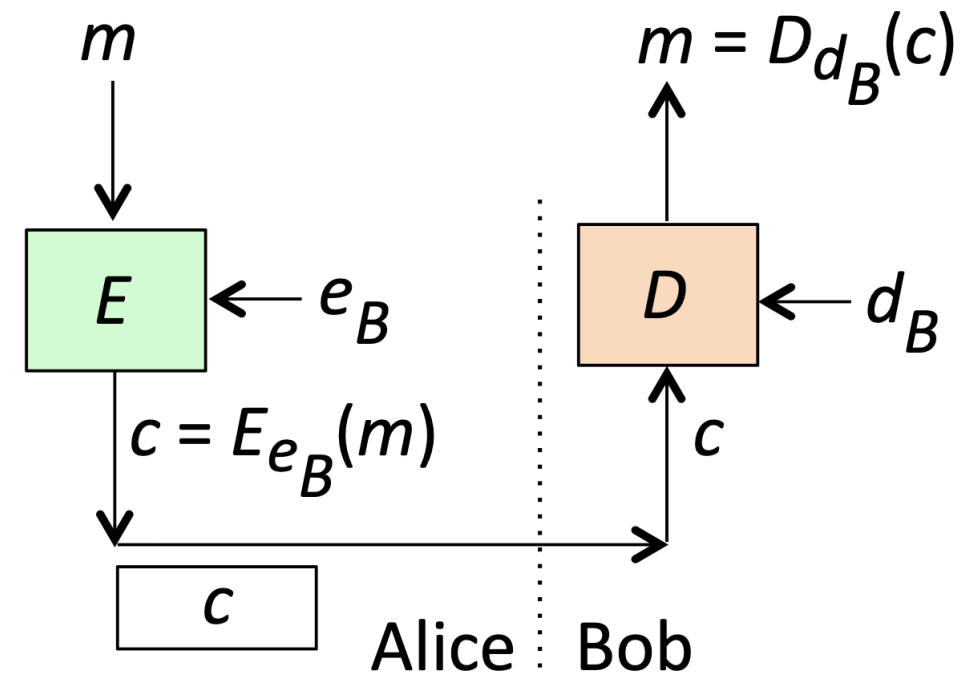
1. **Data Origin Authentication:** Assurance of the *message origin*.
2. **Data Integrity:** Assurance that the message is *unchanged*.
3. **Non-Repudiation:** Prevents the sender from denying having sent the message.

a) Public-key signature



s_A : signing private key (of Alice)
 v_A : verification public key (of Alice)

b) Public-key encryption



d_B : decryption private key (of Bob)
 e_B : encryption public key (of Bob)

Digital Signatures with Hashing

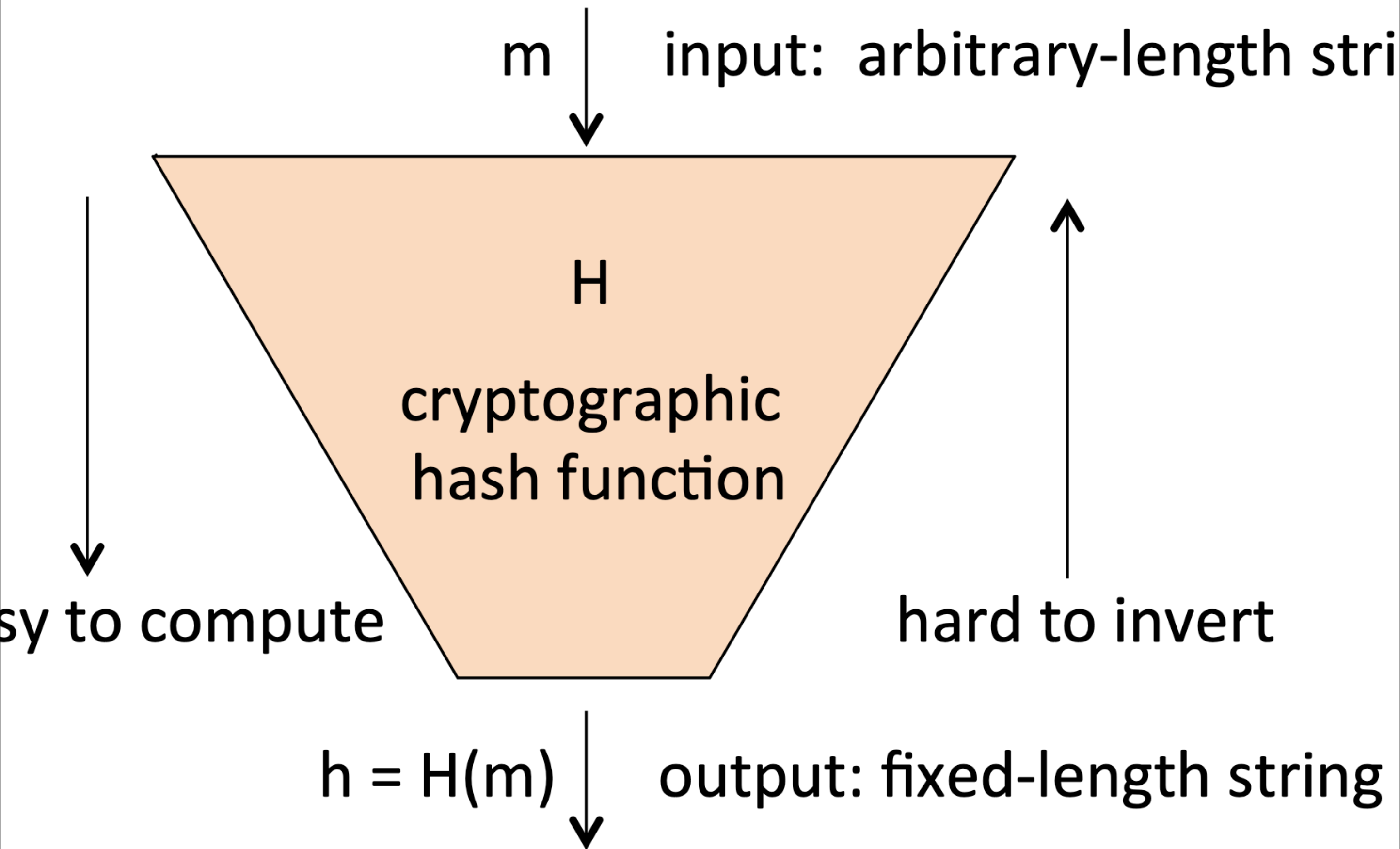
Process

Digital signatures are often used with **hash functions** to efficiently **sign** messages.

– Steps

1 Compute the hash $h = H(m)$.

2 Sign the hash $t = S_{s_A}(h)$.

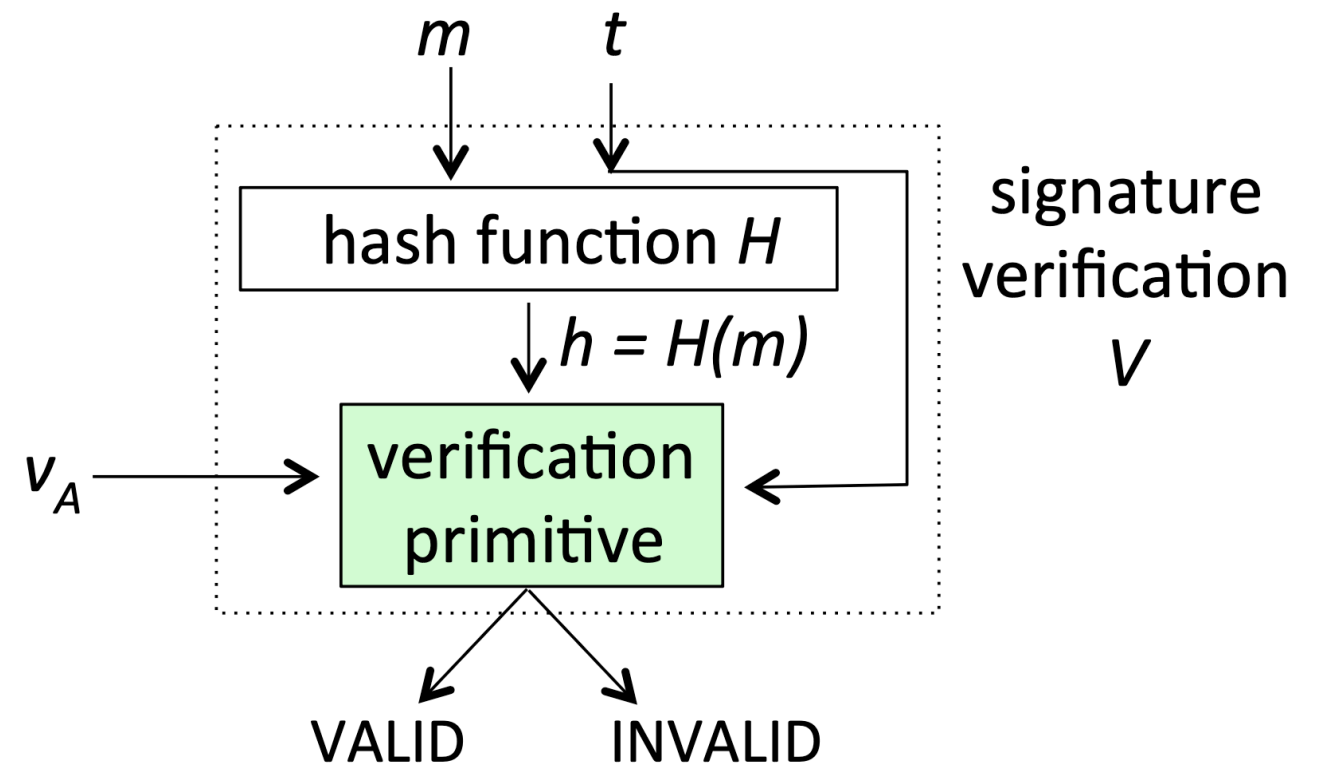
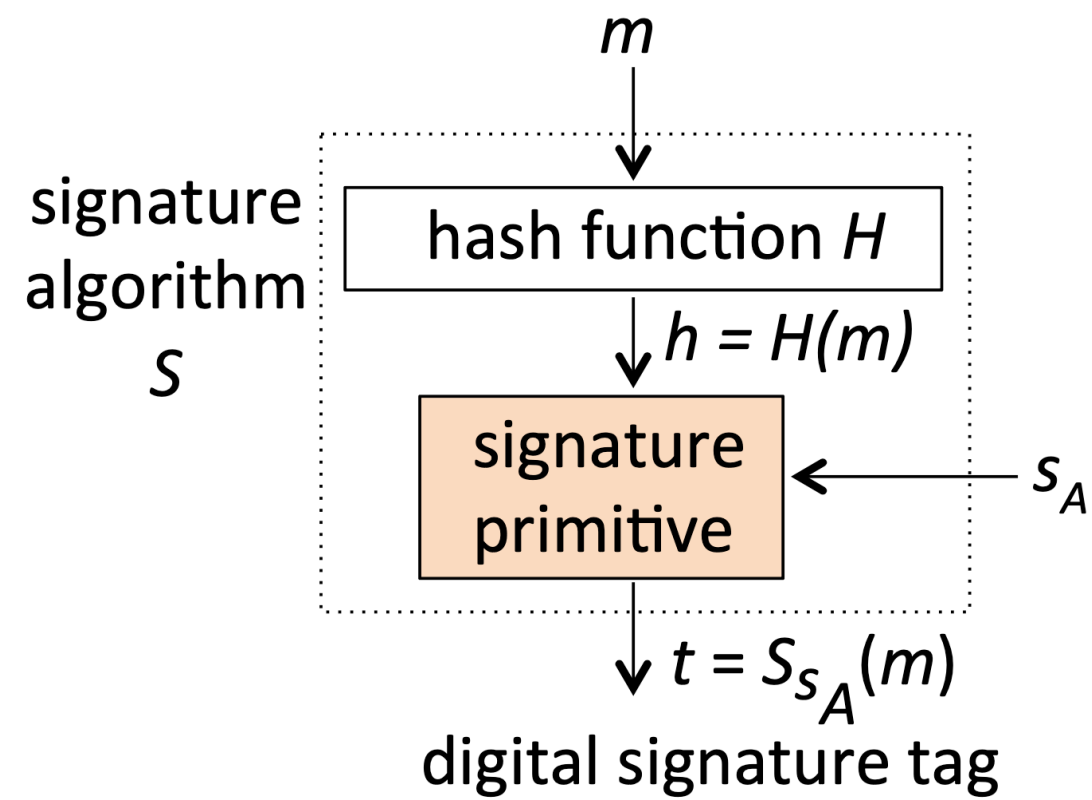


Cryptographic Hash Functions

Hash functions take an input of **any length** and produce a **fixed-length** output called a **hash value**.

Cryptographic Hash Function Properties

- 1 **One-Way Property:** Hard to find the input given the hash value.
- 2 **Second-Preimage Resistance:** Hard to find a second input with the same hash.
- 3 **Collision Resistance:** Hard to find any two distinct inputs with the same hash.



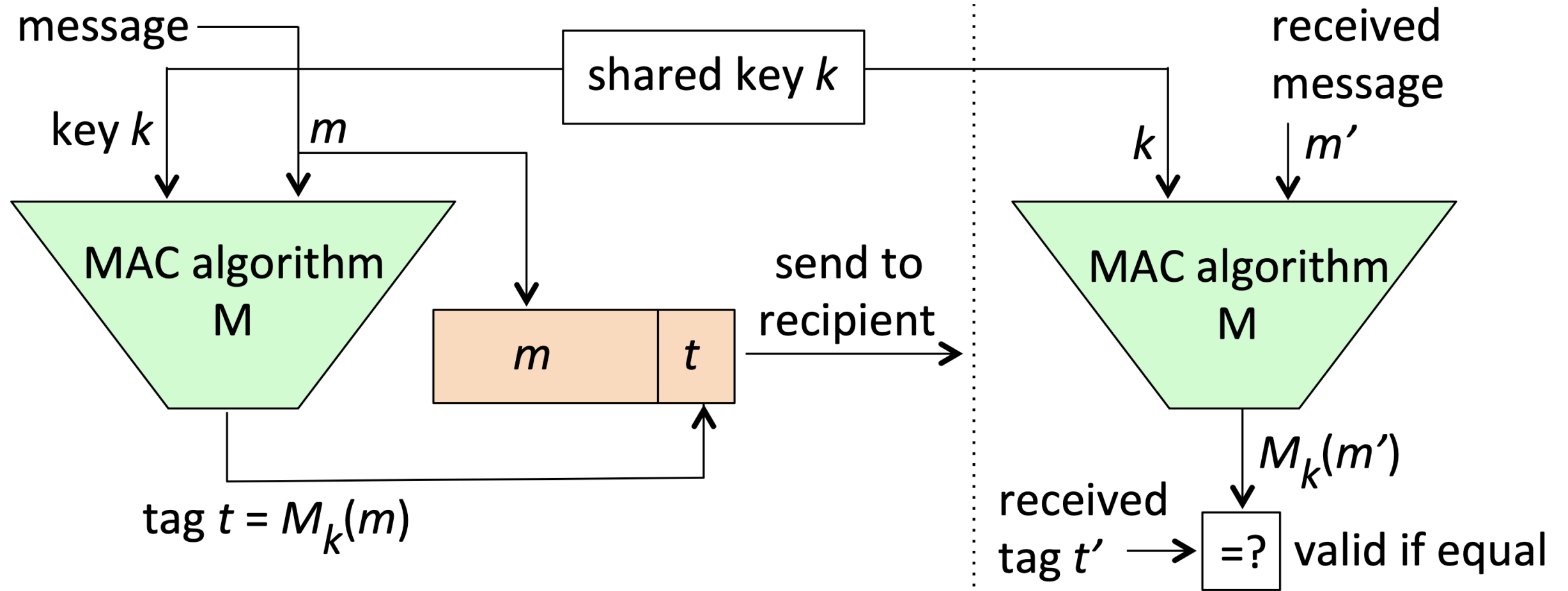
Message Authentication Codes (MACs)

Message Authentication Codes (MACs)

MACs ensure the **integrity** and **origin** of a message by appending a tag generated using a secret key.

– Process

- 1 Compute the tag $t = M_k(m)$.
- 2 Verify the tag using the same key **k**.



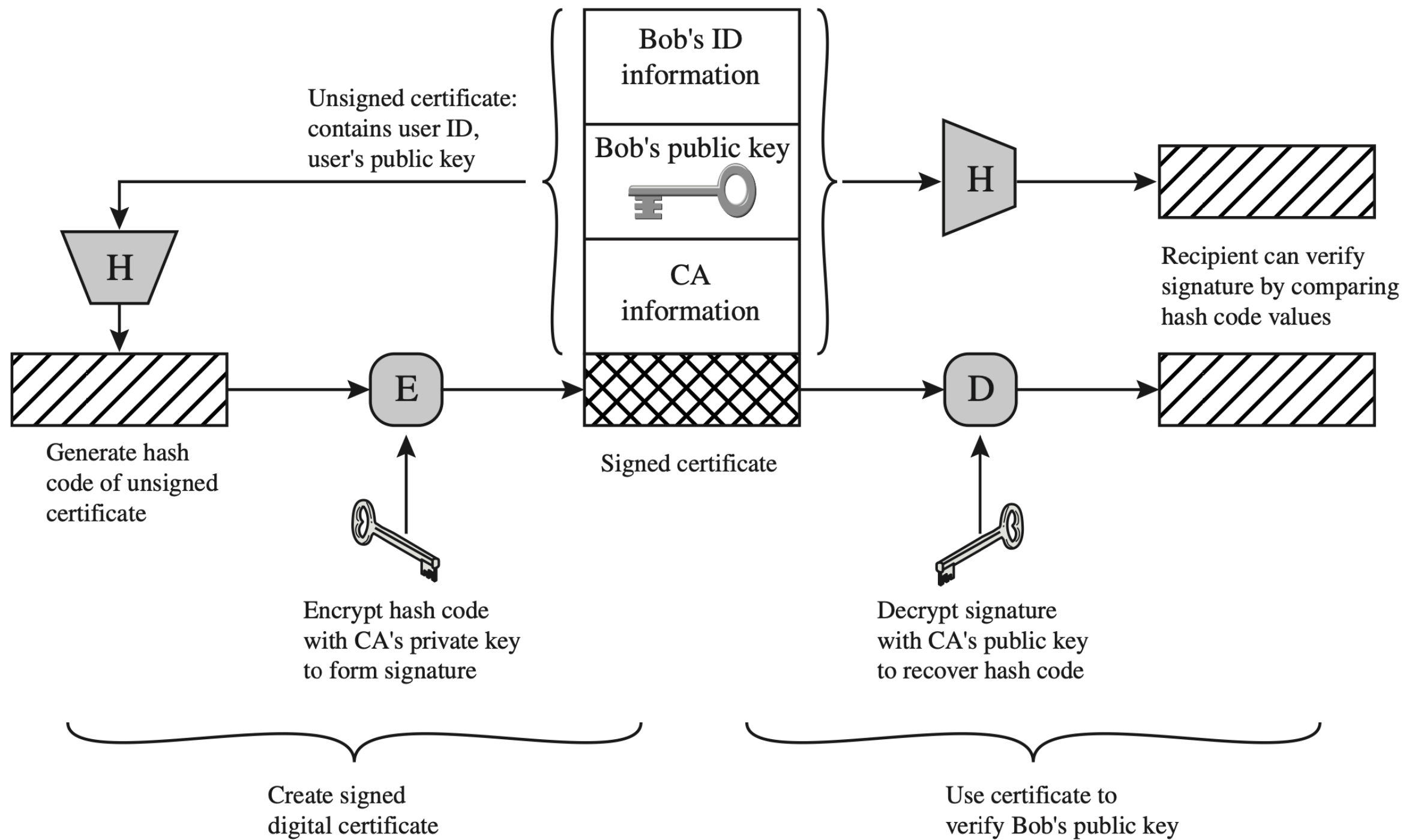
Certificates and Public- Key Infrastructure (PKI)

Integrity of Public Keys

Public keys must be authenticated to ensure they belong to the correct entity. Substituting an encryption public key with an opponent's key compromises security.

Public-Key Certificates

A public-key certificate binds a public key to an owner using a digital signature from a trusted Certification Authority (CA).



Certificate Fields

Certificates include several fields:

- **Version:** Certificate format version (e.g., X.509v3)
- **Serial Number:** Uniquely identifies the certificate
- **Issuer:** CA's name
- **Validity Period:** Dates (Not-Before, Not-After)
- **Subject:** Owner's name
- **Public Key Information:** Algorithm and key value
- **Extension Fields:** Additional attributes like Subject-Alternate-Name, Key Usage, etc.
- **Signature Algorithm and Digital Signature:** Used by the CA

Field name	Contents or description
Version	X.509v3 or other versions
Serial-Number	uniquely identifies certificate, e.g., for revocation
Issuer	issuing CA's name
Validity-Period	specifies dates (Not-Before, Not-After)
Subject	owner's name
Public-Key info	specifies (Public-Key-Algorithm, Key-Value)
extension fields (optional)	Subject-Alternate-Name/SAN-list, Basic-Constraints, Key-Usage,CRL-Distribution-Points (and others)
Signature-Algorithm	(algorithmID, parameters)
Digital-Signature	signature of Issuer

Certification Authority (CA) Responsibilities

Before Issuing Certificates

CAs must:

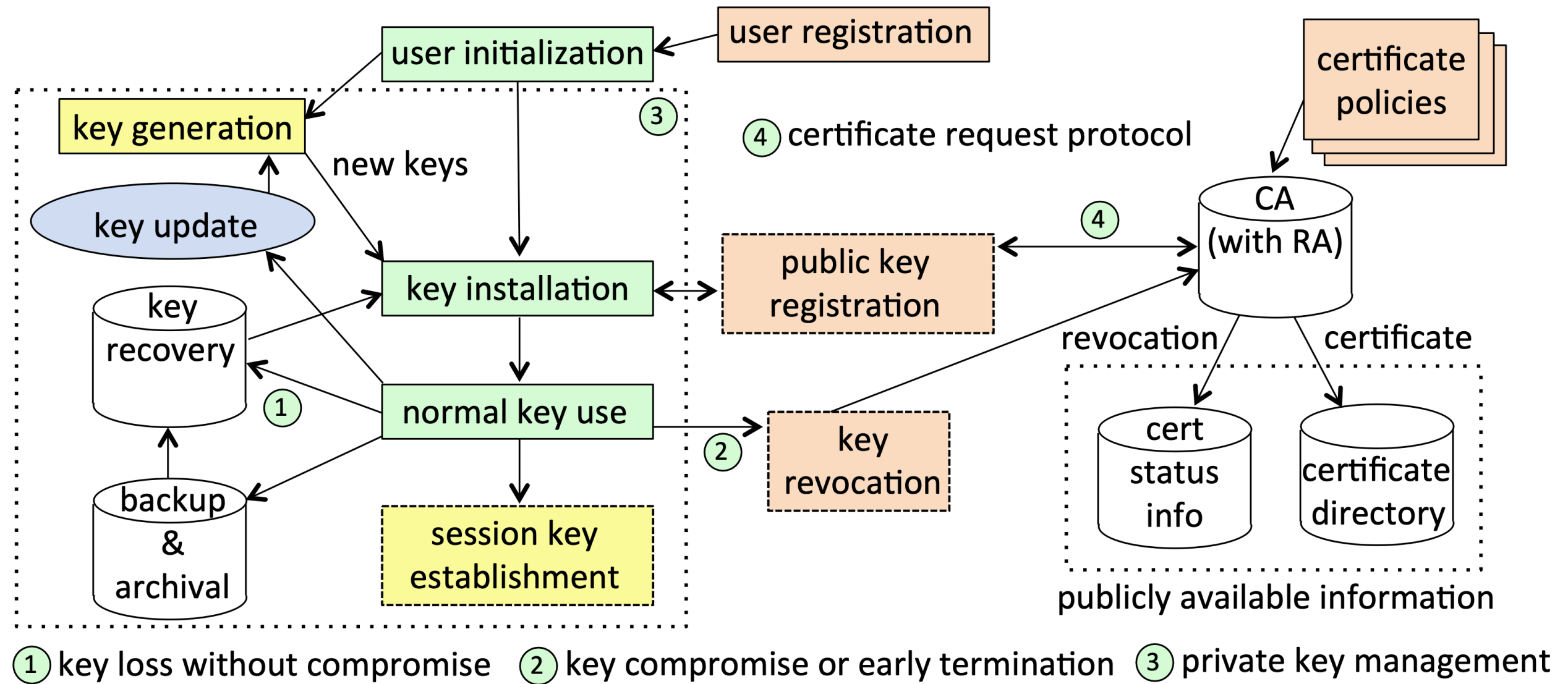
1. Verify knowledge of the private key.
2. Verify control of computer-addressable identities (e.g., domain names, email addresses).
3. Confirm asserted natural-world names for high-quality certificates.

Acquiring a Certificate

End-entities request certificates from CAs, usually providing a Distinguished Name (DN), public key, and other attributes.

Public-Key Infrastructure (PKI)

PKI is a framework for managing public keys, private keys, and their use by applications. It includes data structures, cryptographic toolkits, architectural components (like CAs), and protocols for key management.



Practical Considerations

Using Cryptographic Toolkits

- Guidelines

- 1 Use well-tested and widely accepted cryptographic algorithms and protocols.

- 2 Avoid designing your own cryptographic protocols or algorithms.